

OAuth Service: fixed first-live endpoints

Goal: one privately provisioned ADMIN signs in to the React editor; public visitors read published notes without login. This page freezes the required OAuth surface for this release. UI preview mode is turned off only when these routes and Notes APIs work.

Method / path	What it does and exact UI contract
GET /oauth2/authorize	Issuer origin. Authorization Code + PKCE S256. Query: response_type=code, client_id=technotes-web, redirect_uri=http://localhost:5173/auth/callback, scope, state, nonce, code_challenge, code_challenge_method=S256. After login redirect with code and same state.
GET /login	Issuer browser sign-in page. Spring Security presents a real password form; never accept owner password in the React UI.
POST /login	Issuer browser form submission with session and CSRF protection. Successful sign-in resumes /oauth2/authorize. Framework login route, not a JSON business API.
POST /oauth2/token	Issuer origin. Form: grant_type=authorization_code, client_id=technotes-web, code, exact redirect_uri, code_verifier. Return access_token, token_type=Bearer, expires_in. Public PKCE client: no client secret in React. Allow the exact React origin for browser token exchange.
GET /oauth2/jwks	Issuer origin. Return public JWK Set. Notes validates access-token signature against it; never expose private key.
GET /api/v1/users/me	Gateway-visible business API; bearer + profile.read. 200 direct JSON: {id,displayName,email,roles,status}. 401 for missing/invalid access token; 403 for missing scope. React uses it to open owner workspace.

Fixed configuration and identity

Local issuer http://localhost:9000; UI http://localhost:5173; Gateway http://localhost:8080. Register exact callback http://localhost:5173/auth/callback. Provision Shakti account privately in PostgreSQL with ACTIVE status and ADMIN (plus AUTHOR if Notes requires it). Scopes: openid profile notes.read notes.write notes.review taxonomy.write profile.read. Access token: exact iss, immutable UUID sub, aud=[technotes-api], space-separated scope, roles array, iat, nbf, exp. Signing key and OAuth authorization state persist across restart.

Definition of done

Login returns to /auth/callback; code+verifier exchange succeeds once; /users/me returns the owner identity; Notes accepts this token and rejects wrong issuer/audience/signature/expiry or an ID token. Wrong PKCE verifier and replayed code fail. Browser origin/CORS and redirects match exactly. For AWS later replace all three origins with reviewed HTTPS values and register the exact production callback.

Out of scope for this live release

No public registration API, admin user-management API, password reset, email verification, refresh-token flow, introspection/revocation or Premium roles. Framework discovery/OIDC metadata may be exposed by the configured authorization server, but the UI does not call them. Do not create extra custom endpoints to replace the framework protocol.

Source: TechNotes User/OAuth Service spec v1 and First Live Release API Contract. Endpoint paths are frozen for this UI; internal classes, database schema and configuration remain implementation choices subject to the stated security behavior.